

Agenda

- Class 12 – October 12th (10:30 – 12:30)
- Starter Quiz
- Security Architecture
- Thought Paper Presentation
 - Consumer Persona's (Micro and Small Business) – Banking Usage and Needs Analysis (Team 9) - 30 mins
- Security Architecture (Cont'd)

Note:

- Mobile Phones – Do not bring to class or Completely Switch off
- If students have any specific topic they want to discuss, share the topic and we can try to schedule
- Please be seated by your teams

Starter Quiz

- What are the 5 Key Attributes of an Investment Category (i.e. attributes that should be assessed when doing an Investment)



5 Key Attributes

- 
- Risk
 - Return
 - Liquidity
 - Cash Flow
 - Taxation

Starter Quiz

- **Structural Shift of Wealth from West to East using some Data Metrics**

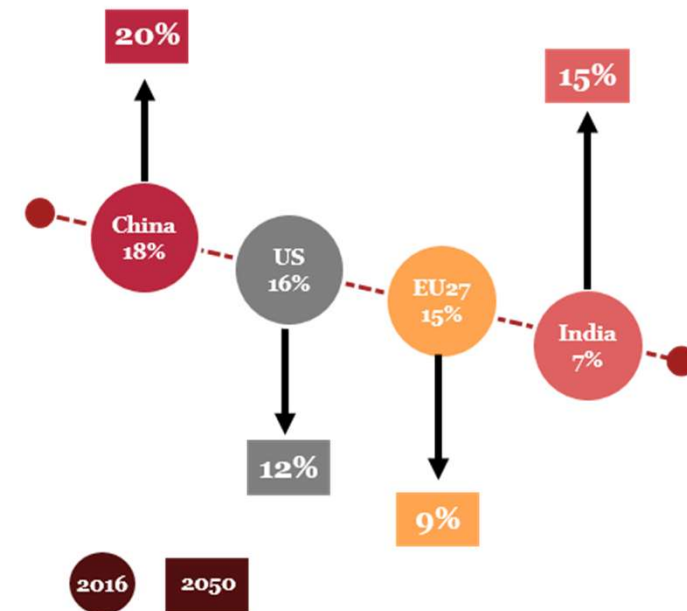
Structural Shift of Wealth from West to East – Some Data Metrics

Country / Region	1980 (Nominal GDP)	2025 (Nominal GDP)	2050 (Nominal GDP)
EU	\$3.3 Trillion	\$19.9 Trillion	\$28 Trillion
China	\$302 Billion	\$19.2 Trillion	\$42 Trillion

Country / Region	1980 (Nominal GDP)	2025 (Nominal GDP)	2050 (Nominal GDP)
UK	\$1.15 Trillion	\$3.8 Trillion	\$5.3 Trillion
India	\$320 Billion	\$4.2 Trillion	\$25 to \$30 Trillion

The US and Europe will steadily lose ground to China and India

Share of world GDP (PPPs) from 2016 to 2050...



Sources: IMF for 2016 estimates, PwC analysis for projections to 2050

Note: In 1600 China (29%) and India (23%) constituted 50% of World GDP

Core Banking Platform Engineering – Security Architecture

Security Architecture – Topics Covered

- **Authentication**
- **Authorization**
- **Encryption**
- **Masking**
- **Security Scanning and Testing**
- **Industry Standards**

Authentication

Authentication Overview



Identity Verification

Authentication ensures users are who they claim to be before accessing sensitive systems or data.

Common Authentication Methods

Passwords, biometrics, and multi-factor authentication are widely used to confirm user identities securely.

Importance

Strong authentication is essential for protecting sensitive data and preventing unauthorized access in digital environments.



Authentication – Single Factor and Multi Factor

Single Factor Authentication

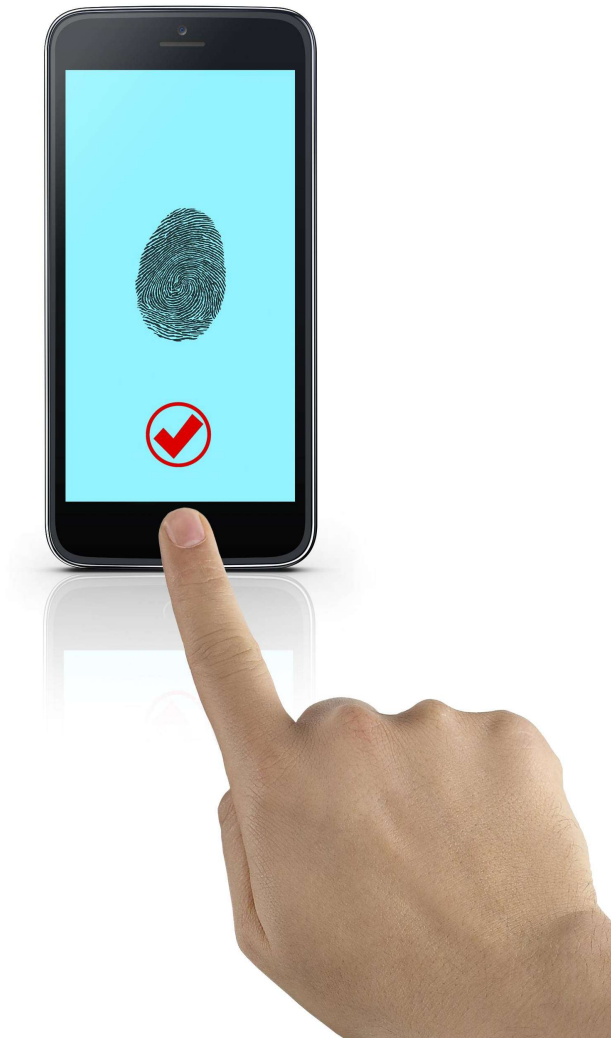
Single factor authentication relies on one credential, usually a password, for identity verification. This method is simple but less secure.

Multi Factor Authentication

Multi factor authentication uses two or more factors, such as passwords, biometrics, or tokens, to enhance security and prevent unauthorized access.

Security Comparison

While single factor authentication is straightforward, multi factor offers stronger protection, especially for sensitive accounts and data.



Authentication Approaches

Multi-Factor Authentication

Multi-factor authentication uses a combination of factors such as passwords, devices, or biometrics to enhance security.

Biometric Authentication

Biometric authentication verifies identity with physical traits like fingerprints or facial recognition, offering enhanced convenience and security.

Passwordless Authentication

Passwordless authentication uses methods like one-time codes or push notifications for secure and user-friendly login experiences.

JWT Token

Secure Information Transmission

JWT (JSON Web Token) enables secure data exchange between parties by encapsulating information in a digitally signed JSON object.

User Authentication Process

After authentication, a JWT is generated and sent to the client, who uses it in future requests

Stateless Identify Verification

JWTs enable stateless authentication, allowing servers to verify user identity without storing session data.

JWT Structure: Header, Payload, Signature

Header: Token Information

The header identifies the type of token and the cryptographic algorithm used for signing, ensuring clear protocol and security.

Payload: Claims and Data

The payload contains the claims, which are statements about the user and additional data being securely transmitted.

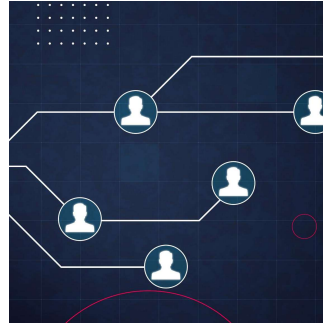
Signature: Integrity Verification

The signature verifies the token's authenticity and integrity, ensuring it has not been tampered with during transmission.



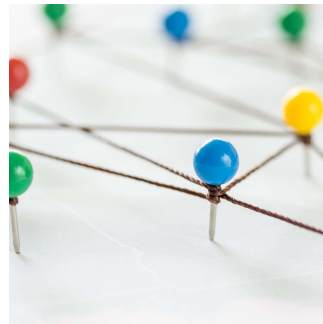
Authorization

Role Based Authorization



Assigning Permissions by Role

Access permissions are granted based on user roles, making it easier to manage who can access specific resources.



Simplified Security Management

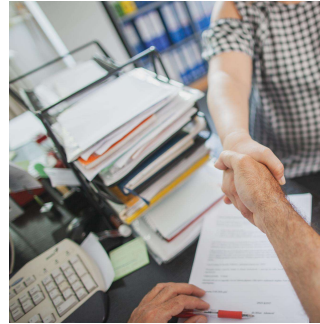
Grouping users and privileges by role streamlines security administration and reduces complexity in managing access.



Enhanced Data Protection

Users only access resources needed for their roles, which helps prevent unauthorized actions and minimizes data breach risks.

Maker-Checker Authorization



Dual Transaction Oversight

Maker initiates a transaction and checker reviews and approves it, ensuring thorough oversight and accountability.



Error and Fraud Reduction

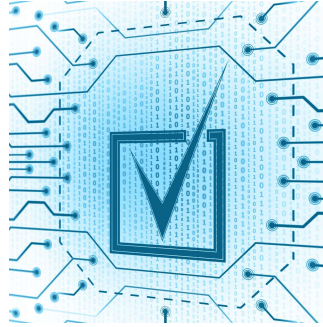
The process minimizes errors and prevents fraud by requiring authorization from two individuals for each transaction.



Critical Industry Application

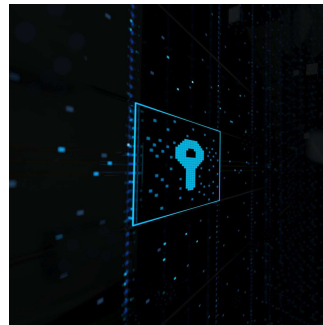
Commonly used in banking, specially for sensitive functions like Interest Rate Change or Product Config Changes etc..

Value Based Authorization



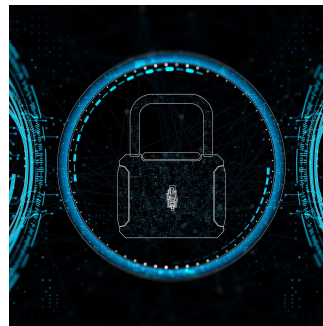
Attribute-Based Access Control

Value Based Authorization uses specific attributes such as Amount (e.g. Loan Amount or Transaction Amount) or location (e.g. when Branches are getting being closed or being sold) or Products (Special Products) or Customer Segments (e.g. VIP Customers like Royal Family) or Restricted Accounts (e.g. Owner has passed away) to grant access, not just user roles.



Fine-Grained Security

This method allows for detailed and precise control, ensuring users meet exact criteria before approval.



Real-Time Data Consideration

Real-time information such as Transaction Amount or Loan Amount can influence access decisions dynamically.

OAuth2 Protocol

Secure Authorization Standard

OAuth2 ('Open Authorization') is an industry-standard protocol for authorization.

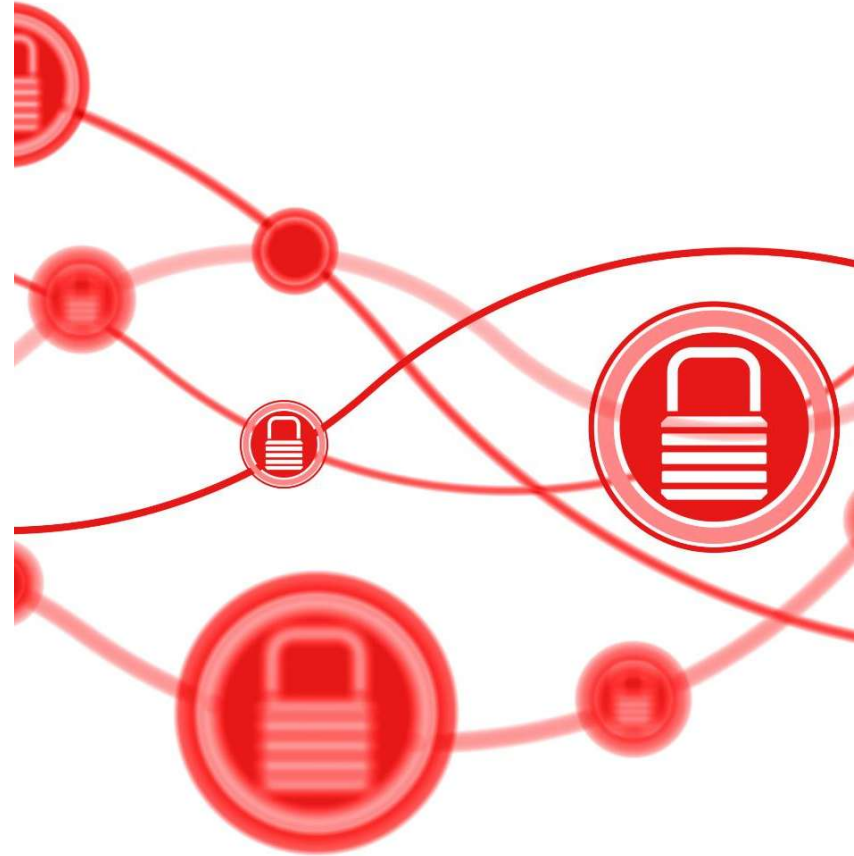
OAuth2 is designed to work with HTTP, making it ideal for securing API access.

Access Tokens and Permissions

OAuth2 uses access tokens to provide limited and controlled permissions, ensuring third-party apps only access necessary user data.

Enhanced Privacy and Security

By separating credentials from authorization, OAuth2 protects user privacy and strengthens platform security across various services.



JWT vs OAuth: Key Differences

JWT: Authentication Token

JWT is a compact, secure token format used for transmitting information between parties. It ensures data authenticity and integrity.

OAuth: Delegated Access Control

OAuth is an authorization protocol allowing users to grant access to resources without sharing their credentials.



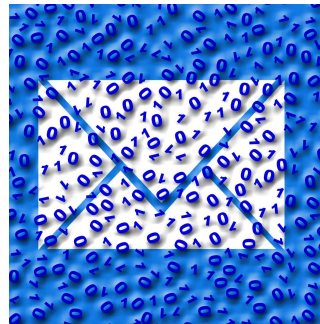
Encryption

Encryption Overview



How Encryption Works

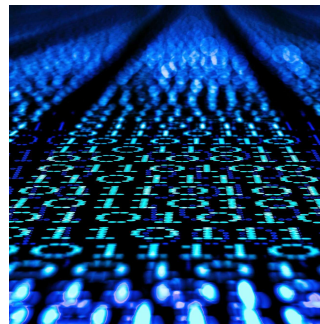
Encryption transforms readable data into an unreadable format, ensuring confidentiality and protecting information from unauthorized access.



Banking Usage

Encryption is vital for critical applications like Core Banking Platforms and is widely used for both “Data at REST” and “Data in Motion”

Compliance standards like PCI DSS require encryption of payment card data to prevent fraud and unauthorized access.



Encryption Methods

Encryption relies on complex algorithms and unique keys, making it highly effective against unauthorized access.

Encryption Types

Symmetric Encryption

Symmetric encryption uses one key for both encrypting and decrypting data, offering faster performance but risks if the key is exposed.

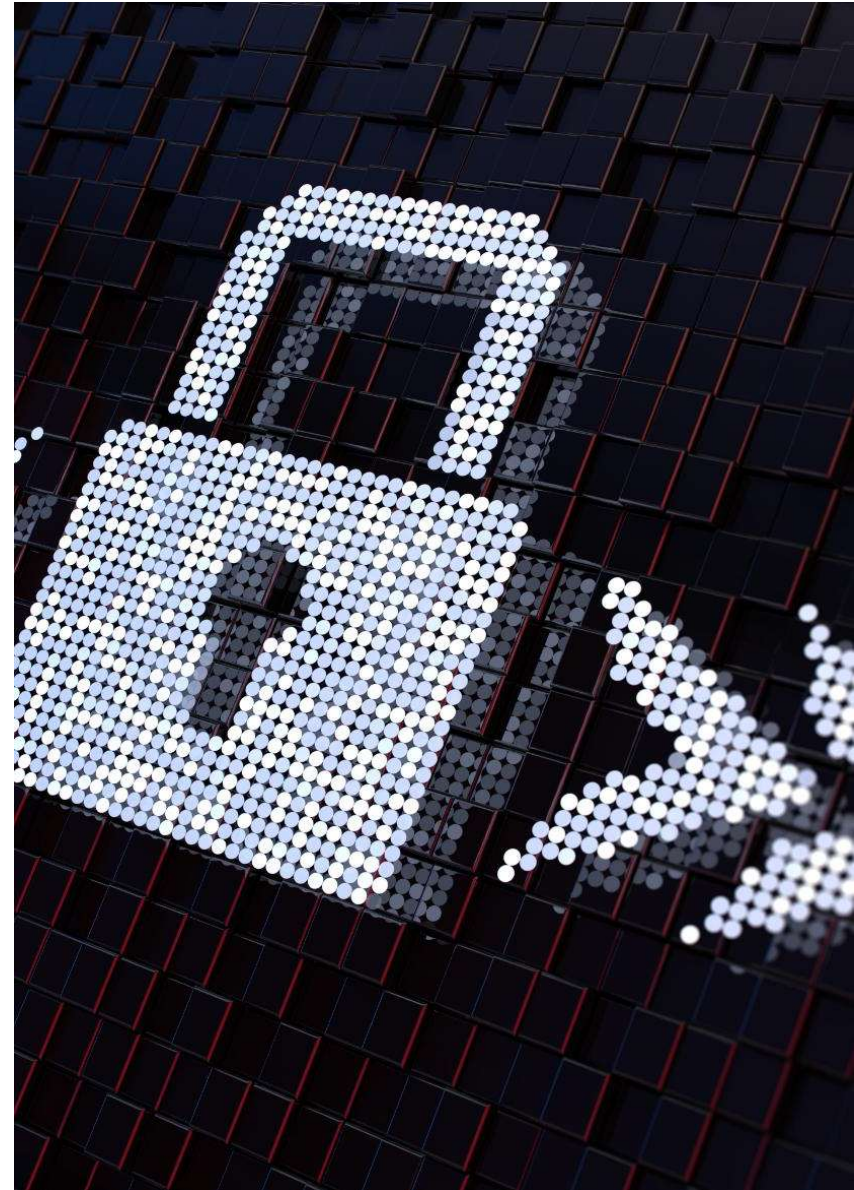
AES is an example of Symmetric Encryption.

Asymmetric Encryption

Asymmetric encryption relies on a public key for encrypting data and a private key for decrypting it securely. Enables secure communication over open networks and improves security by avoiding key sharing.

Algorithms like RSA and ECC use complex mathematics to generate secure key pairs for encryption.

Only the intended recipient with the private key can access encrypted information, preventing unauthorized data exposure.





Encryption: Rest and Motion

Encryption at Rest

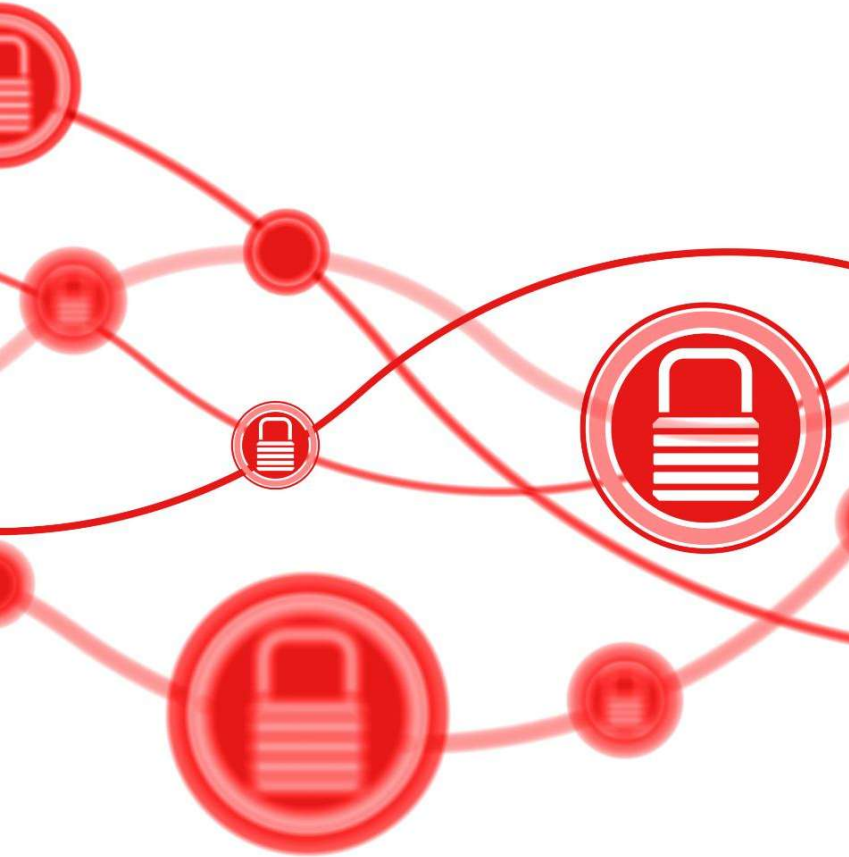
Encryption at rest protects sensitive information stored on databases, files (Disks) from unauthorized access and ensures data remains confidential.

Encryption in Motion

Encryption in motion safeguards data as it moves across networks, preventing interception or tampering during transmission.

Comprehensive Data Security

Using both encryption methods is essential for data security and regulatory compliance.



Data in Motion – API Encryption

Protecting Data in Motion

Encryption secures sensitive information as it travels between clients and servers, shielding it from interception and theft.

API Gateway

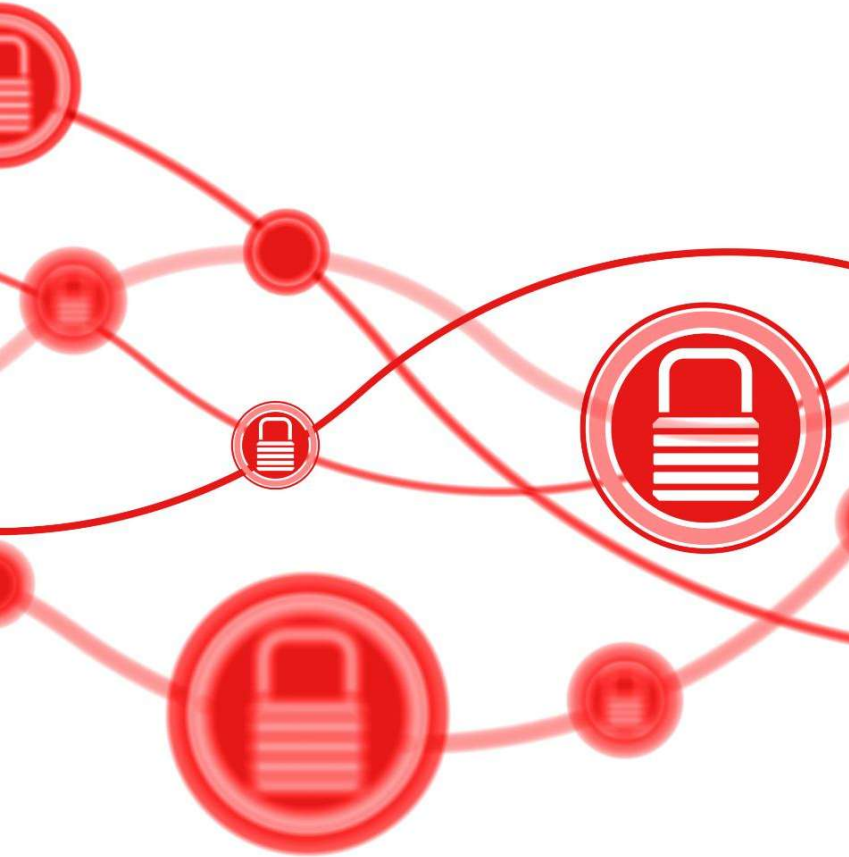
The API Gateway manages encryption, authentication, and rate limiting for both external and internal clients.

Protecting API Headers

Encrypting API headers shields sensitive metadata such as authentication tokens from interception.

Securing Data Payloads

Encrypting the payload prevents unauthorized access and preserves data integrity throughout API communications.



Data in Motion – Event Encryption

Protecting Transmitted Data

Encryption secures event data as it travels across networks, maintaining confidentiality and preventing unauthorized access.

Ensuring Confidentiality and Integrity

Readable events are converted to unreadable formats, making them accessible only to authorized recipients and preventing tampering.

Event Header Encryption

Event headers often hold metadata and may be partially encrypted to hide crucial information from unauthorized access.

Event Payload Encryption

Event payloads contain core data and are fully encrypted, ensuring confidentiality and protection from data breaches.

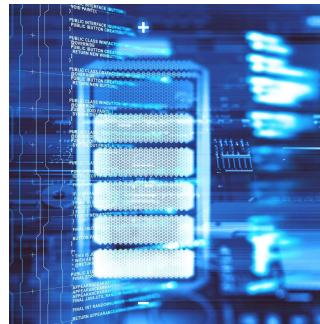
.

Data at REST - TDE Encryption for Database



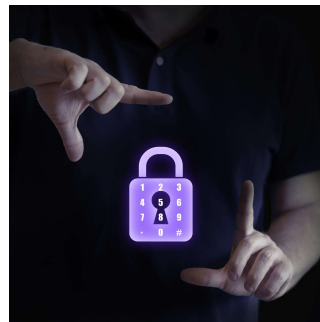
Protection of Data at REST

TDE is used for Database Encryption, ensuring information stored in the database remains secure and inaccessible to unauthorized users.



Seamless Real-Time Encryption

Data and log files are encrypted in real-time without the need for application modifications, simplifying deployment.



Master Key and Certificates

TDE leverages a master key and certificates to manage encryption, ensuring compliance and enhancing security protocols.

TDE Challenges

Managing Performance Overhead

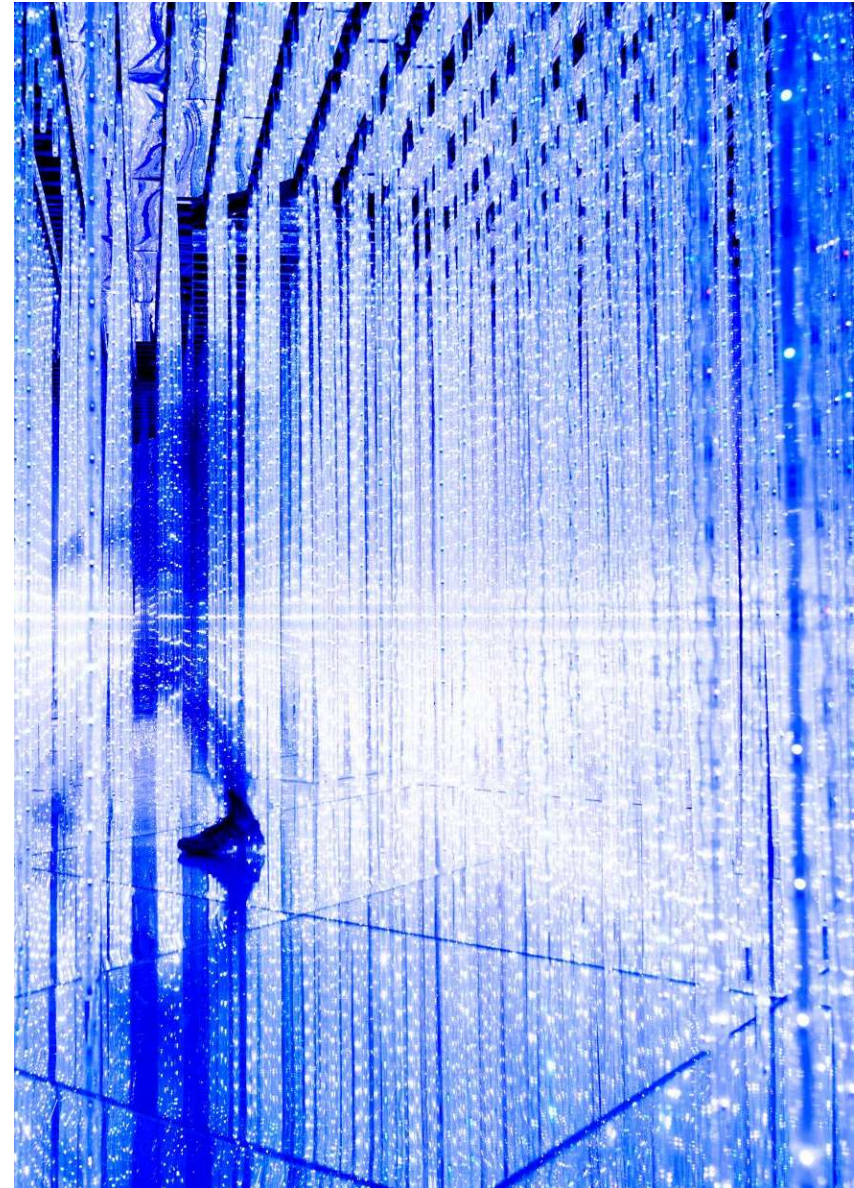
TDE introduces real-time encryption and decryption, which may affect system performance and require optimization.

Secure Key Management

Handling encryption keys securely demands robust policies and specialized tools to protect sensitive data.

Addressing Compatibility Issues

Backup, restore, and migration can encounter compatibility issues, requiring thorough planning and testing.





Column Level Encryption

Protecting Sensitive Fields

Column encryption secures confidential data by encrypting only specific fields, reducing unnecessary exposure and enhancing privacy.

Granular Access Control

Authorized users are granted access to encrypted columns, providing precise control over who can view sensitive information.



TDE vs Column Encryption

Transparent Data Encryption

TDE encrypts the entire database at rest, safeguarding backups and logs with minimal application changes.

Column Level Encryption

Column Encryption secures specific sensitive fields, offering detailed protection during processing and data transfer.

Choosing the Right Approach

The choice depends on compliance, performance needs, and application complexity, balancing security and efficiency.

Data at REST - File Encryption

What is File Encryption

File encryption is the process of converting data into unreadable format using a mathematical algorithm (a cipher) to prevent unauthorized access. To access the original information, the "ciphertext" must be decrypted with a unique "key". This process protects sensitive information when files are at rest (or even in transit i.e. when exchanging Files across Networks).

Privacy and Security Benefits

File encryption secures sensitive information, preventing unauthorized access and data breaches.

Major File Encryption Tools

Enterprise file encryption tools include solutions like Symantec Encryption & VeraCrypt, they offer AES 256 encryption. .



Encryption General Challenges

Balancing Security and Performance

Encryption can introduce latency, impacting performance especially in real-time processing systems.

Key Management Complexity

Securely storing, rotating, and distributing encryption keys demands robust infrastructure and strict policies.

Legacy System Integration

Integrating encryption with outdated architectures (specially with Corebanking where many banks run on Older Platforms) poses compatibility and support challenges



Data Masking

Data Masking

Obscuring Sensitive Information

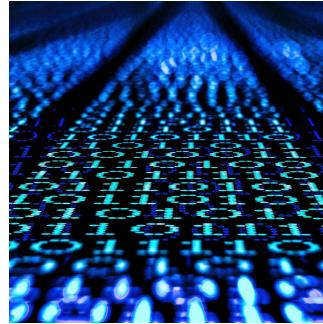
Data masking transforms confidential data, making it unreadable to unauthorized users and enhancing security.

Common Masking Examples

Masking is used to obscure account numbers, credit card numbers, anonymize names, and hide email addresses in test environments or when sending customer communications or in Reports.



Why Data Masking



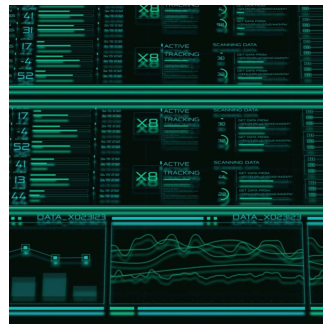
Protecting Sensitive Data

Data masking secures private information in testing and development, reducing the risk of exposure in non-production environments.



Regulatory Compliance

Complying with regulations like GDPR and HIPAA is crucial, making data masking a legal necessity for personal and financial data.



Preventing Unauthorized Access

Obscuring identifiable data in reports and analytics reduces the chances of unauthorized access or misuse by internal or external actors.

TYPES OF DATA MASKING

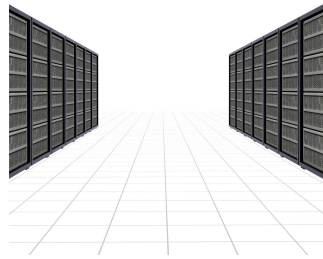
Static Data Masking

Static Data
Masking creates a copy of data and replaces sensitive info with realistic fake data for testing environments.

Dynamic Data Masking

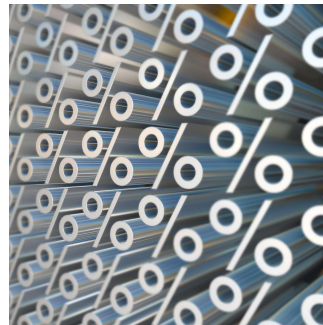
Dynamic Data
Masking masks data in real-time based on user roles to restrict sensitive data access dynamically.

Data Masking Methods



Substitution Method

Substitution replaces sensitive information with fictional but realistic values, preserving data format while protecting privacy.



Shuffling Technique

Shuffling randomly reorders data within a set, making it harder to link information to real individuals.



Character Scrambling

Character scrambling mixes up characters within data fields, preventing easy identification of the original information.

Security Scanning and Testing

Why Security Testing Matters in Core Banking

Protect Sensitive Financial Data

Security testing protects sensitive financial data from breaches and fraud, preserving customer trust and bank integrity.

Validate Security Mechanisms

Testing verifies authentication, encryption, and access controls to ensure banking infrastructure resilience against threats.

Identify and Mitigate Vulnerabilities

Security testing uncovers vulnerabilities early, allowing mitigation before exploitation to safeguard reputation and stability.

Ensure Compliance and Continuity

Testing supports regulatory compliance and operational continuity amidst growing cyber threats and digital transformation.

Types of Security Testing

Static Application Security Testing (SAST)

SAST analyzes source code to detect vulnerabilities without running the software, ensuring early flaw detection.

Three Major SAST Scanning
Application Scanning
Open Source Scanning
Container Scanning

Dynamic Application Security Testing (DAST)

DAST tests running applications to identify security issues during execution, detecting runtime vulnerabilities.

Penetration Testing

Simulates real-world cyberattacks to uncover exploitable weaknesses and improve system defenses.

Compliance

compliance testing ensures regulatory adherence like PCI DSS and GDPR.

SAST – Application Scanning



Early Vulnerability Detection

SAST tools analyze source code to identify security vulnerabilities at the start of development, minimizing risks later.

Cost-Efficient Remediation

Addressing issues early with SAST reduces the cost and effort required to fix security flaws after deployment.

Continuous Integration Security

SAST tools integrate seamlessly into CI/CD pipelines, providing constant code scanning for ongoing security maintenance.

Secure Coding Standards

SAST promotes adherence to secure coding standards, helping teams maintain consistent and secure development practices.

Major SAST – Application Scanning Tools

Veracode, Checkmarx are some of the major SAST Application Scanning Tools used for Enterprise Products/Platforms

SAST - OSS Scanning

Detection of Vulnerabilities

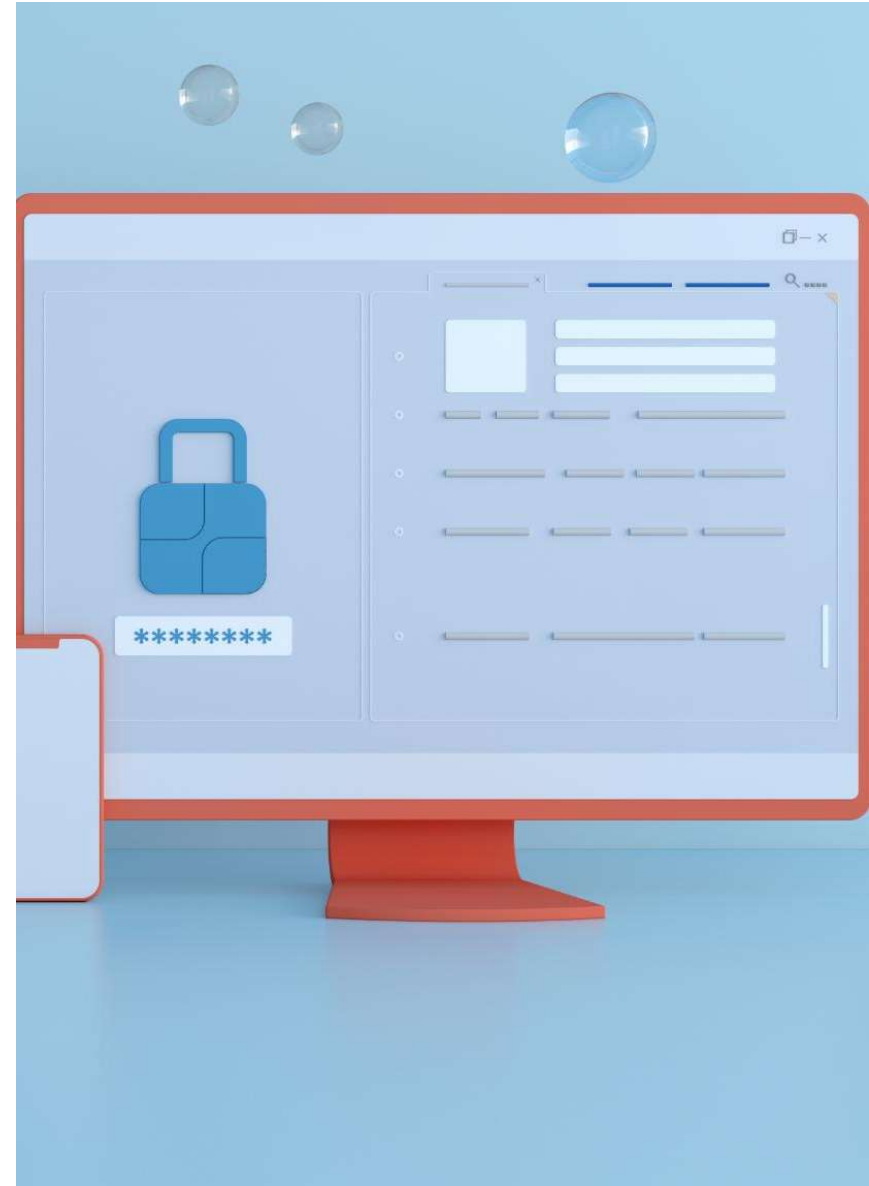
OSS scanning identifies security vulnerabilities in open-source software components, helping teams address risks early in the development process.

Ensuring License Compliance

Assess license requirements of software packages, ensuring projects maintain legal compliance during development and deployment.

Major SAST – OSS Scanning Tools

Blackduck, Synk are some of the major SAST Tools used for Enterprise Products/Platforms

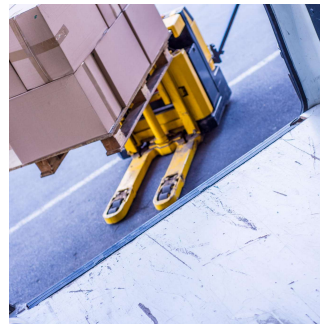


SAST - Containers Scanning



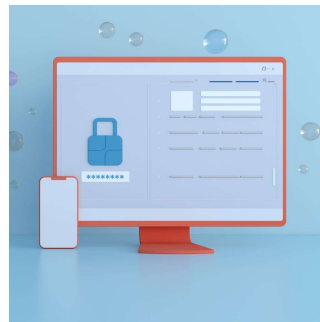
Vulnerability Detection

Security scanning finds vulnerabilities in container images before deployment, helping prevent exploits and attacks in production.



Automated Security Checks and Continuous Image Analysis

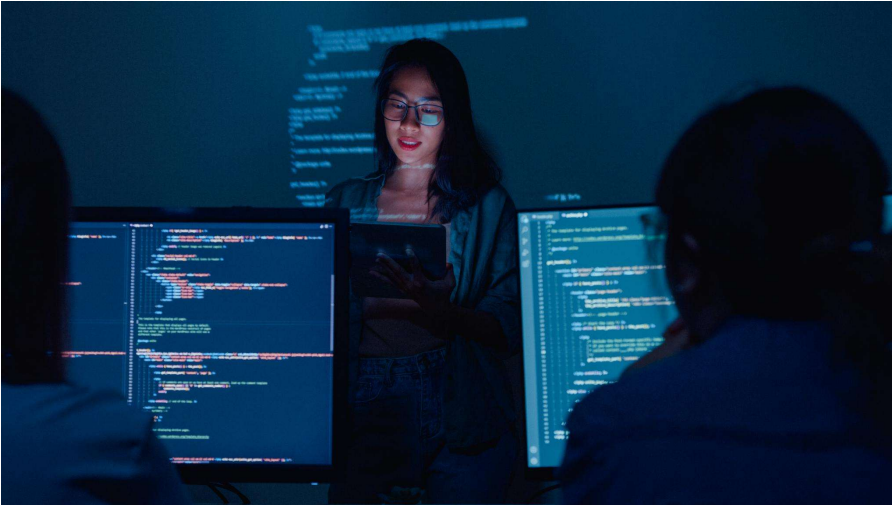
Automated tools identify outdated components, misconfigurations, and known flaws to ensure secure container builds.



Major Container Scanning Tools

Top container scanning tools include Sysdig Secure, Docker Scout that provide comprehensive security and runtime protection, often suited for large enterprises and DevOps

Embedding SAST in CI-CD



Early Vulnerability Detection

Integrating SAST in CI-CD enables teams to find and fix vulnerabilities during the development process, not after deployment.

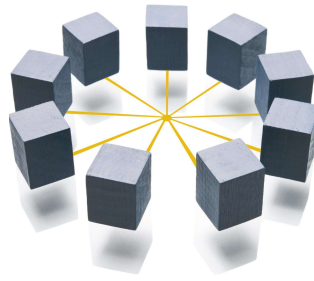
Automated Security Scans

Automated SAST scans in CI-CD pipelines quickly identify code issues, improving software quality and developer efficiency.

Continuous Developer Feedback

Sprint retrospectives review testing metrics to foster ongoing improvements in security and software quality.

SAST Implementation Challenges



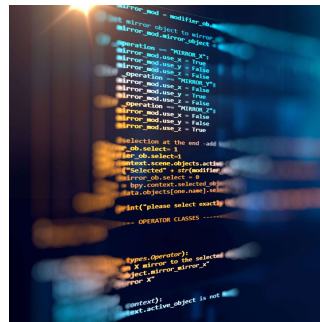
Workflow Integration

Integrating SAST tools into established development workflows and Pipelines can be difficult and may slow release cycles.



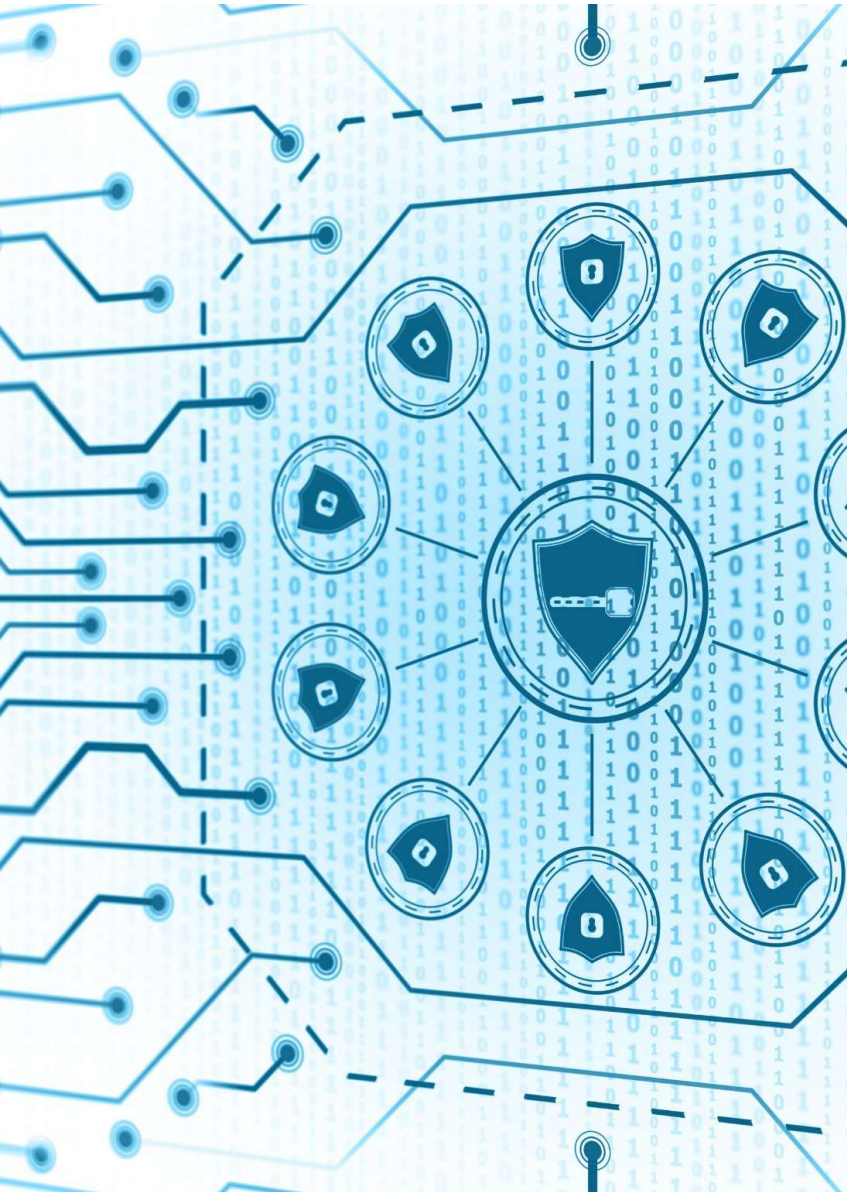
Managing False Positives

SAST tools often produce false positives, making it challenging for teams to priorities and address real security issues.



Adapting to Evolving Codebases

Rapidly changing codebases and new programming languages can reduce the effectiveness of SAST solutions.



DAST Overview

Analyzing Live Applications

DAST tools test running applications to find security flaws, simulating real-world attacks without reviewing source code.

Language-Agnostic Testing

DAST tools work across different programming languages, as they do not require access to the application's underlying source code.

Detecting Runtime Threats

DAST helps identify issues like SQL injection and cross-site scripting, reducing security risks in operational environments.

Major DAST Tools

Veracode Dynamic Analysis, Checkmarx DAST, Blackduck are some of the major SAST Tools used for Enterprise Products/Platforms



Penetration (PEN) Testing

Simulating Cyberattacks

Penetration testing simulates real cyberattacks to uncover potential vulnerabilities in IT systems and infrastructure.

Identifying Security Weaknesses

Organizations identify and understand security weaknesses before attackers can exploit them, reducing risks.

Improving Security Defences

Penetration tests offer actionable recommendations to strengthen security across networks, applications, and sensitive data.

Specialized Certification Team / 3rd Party Certification

Specialized Certification team with Security domain expertise or a 3rd Party Certification Team that specializes in Security Testing is employed to do PEN Testing

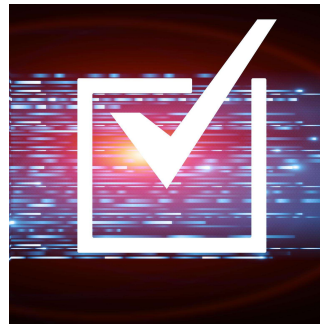
Industry Standards

PCI DSS



Purpose of PCI DSS

PCI DSS is established to protect cardholder data from theft and breaches, ensuring safe transactions worldwide.



Security Requirements

The standard outlines strict requirements for security management, policies, and operational procedures to prevent data breaches.



Mandatory Compliance

All organizations handling payment card information must comply with PCI DSS, safeguarding transactions and building customer trust.

Key PCIDSS Data Fields

Cardholder Data Protection

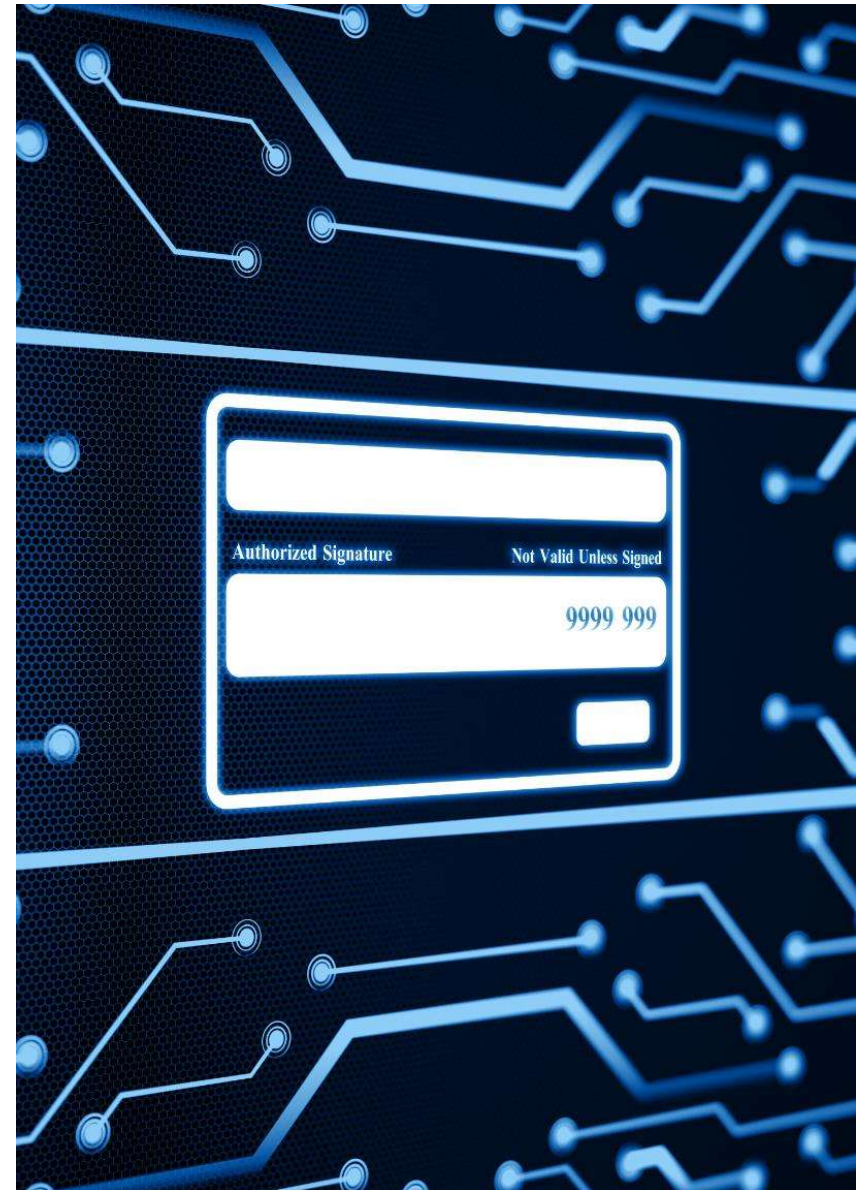
PCIDSS requires safeguarding information such as PAN, cardholder name, expiration date, and service code from unauthorized access.

Sensitive Authentication Data

Sensitive details such as CVC/CVV codes, and PINs must never be stored after authorization.

Encryption and Compliance

Proper encryption and handling of card data are essential for PCIDSS compliance and overall security.





PII Overview

Definition of PII

PII includes any data that can identify a person, such as names, addresses, or ID numbers.

Importance of Protection

Protecting PII is essential to maintain privacy and comply with legal regulations.

Organizational Safeguards

Organizations must use safeguards, manage consent, and handle sensitive information responsibly.

PII Data Fields



Types of PII Data

PII includes information like full name, address, date of birth, and contact details, which can identify individuals.



Sensitive Identifiers

National insurance numbers, passport details, and similar identifiers are sensitive and require special protection under regulations.



Importance of Protecting PII

Safeguarding PII prevents identity theft, unauthorized access, and ensures compliance with data protection regulations.

OWASP

Global Software Security Initiative

OWASP (Open Web Application Security Project) is an international non-profit organization dedicated to enhancing web application security worldwide.

Freely Available Resources

OWASP offers open access to security tools, detailed documentation, and active community-led projects.

OWASP Top Ten Risks

The OWASP Top Ten is widely recognized as the key list for critical web application security risks.

